Security Annex · Mapping Threats to Defense in Depth

Print edition v1.0.0 | 2026-11-11 JST

Author: Masao Takeuchi (Masao Gate Labs). Public edition based on Annex S of the integrated v1.1 series dated 24 October 2026. Microsoft Copilot supported the original research and writing. ChatGPT assisted with public editing and translation.

This is independent research. The acknowledgments indicate assistance and do not imply collaboration, review, approval, or endorsement by the AI providers.

Connect threats to control points

We use threat terminology from OWASP, MITRE ATLAS, and NIST to identify where a control contributes to prevention, detection, containment, or recovery. The table describes the intended role of each control. OWASP · MITRE ATLAS · NIST AI 100-2e2025

Example	Main control role	Remaining work
Prompt injection	Authorize external actions independently to limit out-of-scope effects	Detect and isolate inputs, and assess the trustworthiness of inputs and context
Excessive agency	Separate capability from authority and constrain targets, actions, and redelegation	Verify grant conditions, changes, and revocation
Sensitive information disclosure	Limit and record targets and operations	Classify data and govern outputs, retention, and access
Supply-chain change or poisoning	Detect changes and connect them to reassessment and incident handling	Check provenance and use dedicated controls to detect poisoning
Unbounded consumption	Constrain operations and execution resources	Account for cumulative usage, cost, and alerts under concurrent execution

Consider a read-only task whose agent can see a tool that also offers deletion. If the agent proposes a deletion for which it lacks authority, the enforcement point should deny the action. Execution isolation and protection of data in use address different boundaries. Evaluation should cover suspension and reauthorization and assess what effects remain when one control fails.

Additional interfaces

- **SEC-X1** Provide policy decisions with trust signals for inputs and retrieved context
- **SEC-X2** Validate model outputs before converting them into external actions
- **SEC-X3** Connect resource, runtime, and cost limits to execution controls
- **SEC-X4** Feed provenance and integrity signals for models, tools, dependencies, and data into conformity checks
- **SEC-X5** Apply sensitive-data classifications and handling conditions to authority and enforcement

These interfaces are research proposals. Evaluate coverage and effectiveness under stated assumptions and within a defined observation scope.

Paper 003 · Research series · Case analyses

Pinned web record